

You can use ModSecurity on both the leading Web servers (Apache and IIS).

A typical interaction between an end user, whom we will call Vineet, and ModSecurity (to be called WAF or Web application firewall from now on) may go like this:

- a) Vineet tries to access your application.
- b) He hits the WAF first.
- c) WAF will check the request to make sure that it is safe to go to the application.
- d) If the WAF senses danger, it will take some action (email someone or drop the request); if the WAF deems it alright, it will allow the request to go to the application.
- e) Vineet will either see the application interface (if the WAF thinks it is alright) or will see a warning page (if the WAF thinks that the request was a threat).

Why is ModSecurity useful?

Modern firewalls are very good at the network layers, but they do not understand the intricacies of application security. Consider the following scenario:

- a) You, as a decision maker, have authorised an application to be made accessible over the Internet while hosting it in your network (reasons could be client pressure, staging an application, etc).
- b) You have a firewall that filters all requests coming in from the Internet into your network.
- c) You have to allow this application to connect to the Internet.
- d) You host it on a shared server, along with 15 other applications, and configure your firewall so that it allows this Web application to be accessed through the Internet.
- e) A cyber criminal accesses your application, finds out that it is vulnerable to many weaknesses, uses them to not only get data out of that application (e.g., database details, passwords, user IDs, etc) but also to gain access to the underlying machine. If it has been wrongly configured (hint: application server or Web server running on elevated privileges, etc), the cyber criminal ends up owning your server.
- e) Your company gets sued because a client, upon responding to an incident that happened to its servers, realises that by NOT using a WAF, you have breached a 'due diligence' clause in the contract!

While not intending to spread FUD (fear, uncertainty and doubt), the point here is that securing different parts of your network is not only imperative, it is smart business as well.

ModSecurity provides a range of protection measures (ready-made rule sets like OWASP ModSecurity Core Rules, for example; documentation to help you write new rules, extensive logging, realtime analysis of the HTTP traffic, etc) that can help you secure your existing

applications. These also ensure you comply with any standards, regulations and due diligence norms/laws (like the Indian IT Act, HIPAA, PCI-DSS, ISO 27001, any other contractual obligations with a customer, etc).

Where can it be used?

ModSecurity can be deployed to safeguard your Web applications that are accessible from the Internet AND are hosted in your network. You should do so if you are legally bound to secure them. (More so, if securing a client's network is part of a contractual requirement. The Indian IT Act does expect us to perform 'due diligence' and to meet the contractual requirements of a customer.) The WAF can be deployed as an external security layer without thoroughly disturbing your existing set-up (little tweaks might be needed if you already have an Apache installation running without a ModSecurity module).

One can deploy ModSecurity in either of two ways – embedded or as a reverse proxy. In the embedded mode, it is run as an Apache module and is usually the path to follow if you already have a Web server installation in place and do not want to disturb the existing set-up. This deployment is also seamless to scale as the underlying infrastructure scales. However, be forewarned that it will share your existing system resources with Apache, so do plan for beefing up the server beforehand.

In the reverse proxy mode, ModSecurity is still embedded, but the Apache installation runs as a reverse proxy, which essentially means that it works as a router for Web applications. This deployment will be an additional layer (unlike the embedded mode) without hosting any application on it. This deployment is often preferred by security experts and offers the flexibility to use more server resources and thereby set complicated rules, if your infrastructure demands it. This could be appropriate in the case of a huge application environment which is open to the Internet along with load balancers, or when there are many applications with different requirements/rules, or when there is a complex infrastructure containing both. The reverse proxy mode also puts up a single point of failure, which needs to be thought of during deployment (load balancers for ModSecurity, anyone?).

Features of ModSecurity

Monitors HTTP traffic and log transactions

(selectively and fully): ModSecurity gives you realtime access to live HTTP traffic which can be used for monitoring. You can choose to log all the HTTP requests/responses (which is not recommended as it will seriously impact the resources of the server) or selective logs. You can also choose the